PROJET SPÉCIALITÉ

Cybersécurité u2

Analyse EBIOS RM, Simulations d'attaques
et Plan de sécurisation global

TechnoSite Industrie
Présenter par Clément VAN MELKEBEKE & Idir MOUMOU

Sommaire

01 Contexte et enjeux

02 Architecture du SI

03 Analyse EBIOS RM

04 Simulations d'attaques

05 Plan de sécurisation

06 Architecture cible & Conclusion

Contexte et enjeux

TechnoSite Industrie

Robotique de précision
Site de production automatisé

- Zone IT : AD, ERP, mails
- Zone OT : PLC Siemens, robots IoT
- SCADA cloud (API REST)
- Caméras IP + RFID
- Application web (HTTPS)
- VPN avec le siège

Incidents observés

Anomalies réseau OT
Ralentissements Modbus, interruptions aléatoires

Connexions suspectes firewall
IP d'Asie du Sud-Est et Europe de l'Est

Campagne de phishing
Faux mails helpdesk IT, 2 clics confirmés

Architecture du système d'information

IT VLAN 10	OT VLAN 20	DMZ VLAN 30	Cloud SCADA
AD, ERP, Mails TCP/IP, HTTPS	PLC S7-1500, IoT Modbus, MQTT	App Web, WAF HTTPS/443	Supervision API REST

FIREWALL INDUSTRIEL — Segmentation insuffisante (pas de micro-segmentation, pas de DMZ dédiée)

VPN Siège-Site
OpenVPN UDP/1194 — Pas de MFA

Sécurité physique
12 caméras IP (HTTP) + badges RFID

Analyse EBIOS RM — Vue d'ensemble

Étape 1	Étape 2	Étape 3	Étape 4	Étape 5
Cadrage	**Sources**	**Stratégique**	**Opérationnel**	**Traitement**
Biens essentiels DIC, périmètre	6 acteurs menaçants	4 scénarios stratégiques	Kill chains MITRE ATT&CK	Mesures de sécurité

Résultats clés

4
Scénarios stratégiques

2
Scénarios critiques

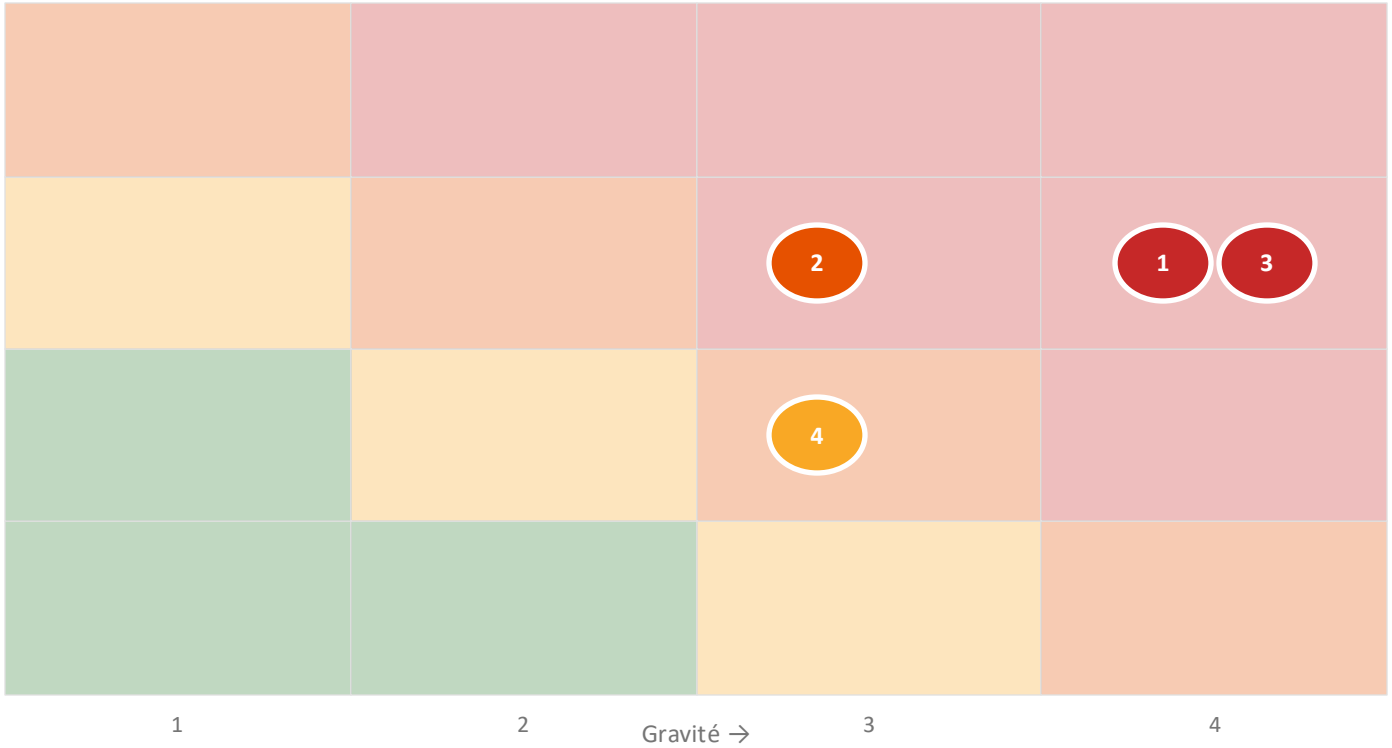
12/16
Criticité max

6
Sources de risque

Sources de risques

Source	Motivation	Capacité	Vraisemblance
Cybercriminel	Gain financier (rançon)	Moyenne	Élevée
Concurrent industriel	Espionnage économique	Élevée	Moyenne
Insider (salarié)	Revanche / profit	Moyenne	Moyenne
Groupe APT (étatique)	Cyber-espionnage SCADA	Très élevée	Faible
Prestataire (supply chain)	Compromis par tiers	Variable	Moyenne

Cartographie des risques



SS-01 Sabotage PLC SS-03 Ransomware SS-02 Exfiltration SS-04 Intrusion physique

Kill chain — Sabotage PLC (SS-01)

Recon	Phishing	Exploitation	Installation	Pivot IT→OT	Sabotage PLC
Nmap Shodan	GoPhish SET	Evilginx2 Cred harvest	Metasploit Cobalt Strike	Mimikatz SSH tunnel	pymodbus Snap7

Constat critique

Un attaquant ayant compromis un poste IT via phishing peut atteindre les automates PLC.

Par exemple La commande : `write_register(100, 9999)` envoie une consigne de vitesse 2x supérieure au maximum autorisé → risque de dommage physique.

Simulations d'attaques — Vue d'ensemble

Scénario	Outil	Résultat clé	Risque confirmé
Phishing ciblé	GoPhish	28% de clics	Formation insuffisante
Scan réseau	Nmap, Nessus	Ports Modbus ouverts	Surface exposée
Exploitation web	Burp, SQLMap	SQLi/XSS exploitables	Absence de WAF
Pivot IT → OT	Metasploit	Accès PLC confirmé	Segmentation faible
Ransomware	Script PowerShell	Détection > 5 min	Backup non testé
MQTT IoT	Wireshark	Données en clair	Pas de chiffrement

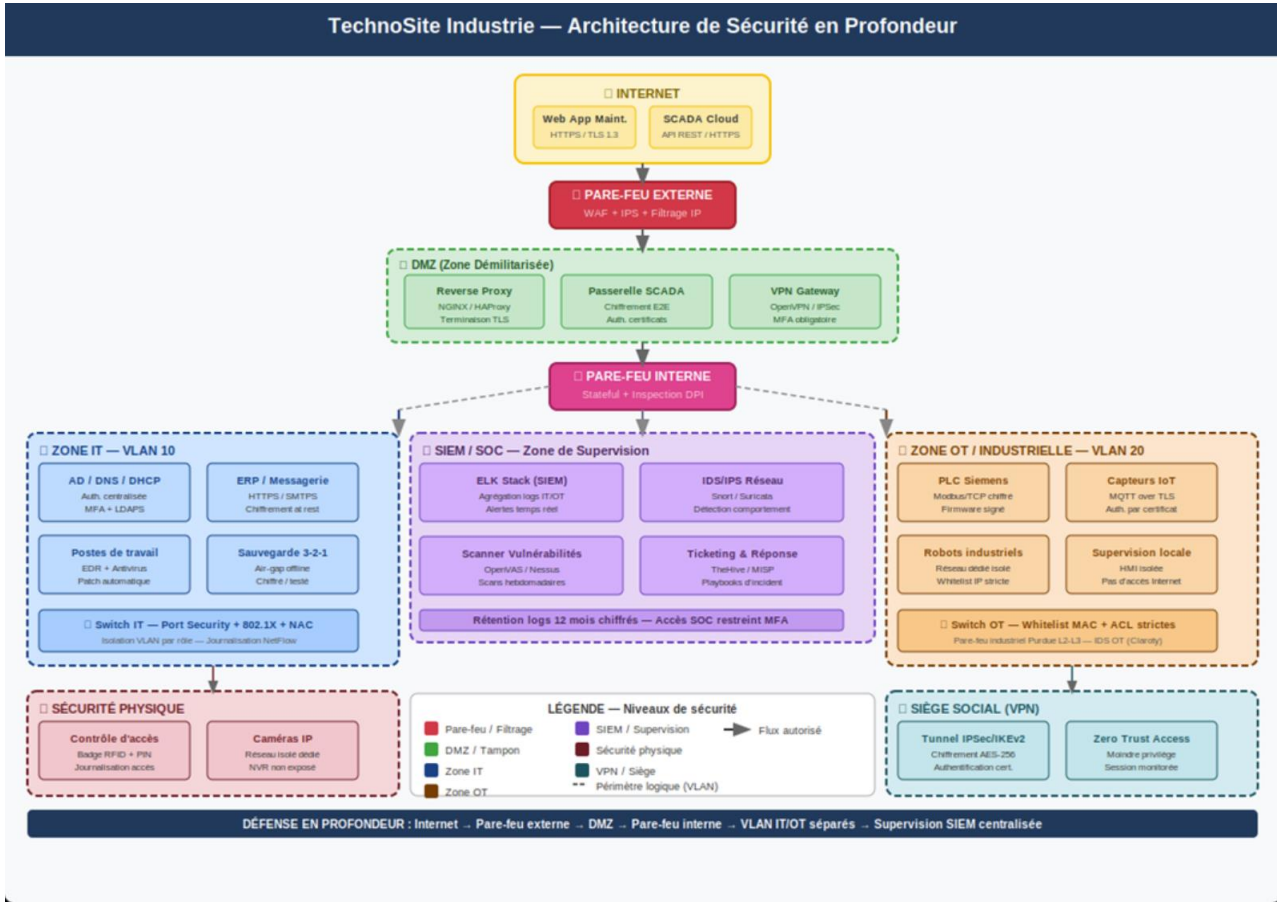
Plan de sécurisation — Mesures techniques

Réseau	Micro-segmentation VLANs IDS industriel (Suricata)	**P1**
Identité	MFA (FIDO2/TOTP) Tiering model AD	**P1**
Endpoint	EDR/XDR sur IT WAF sur app web	**P1**
Données	MQTTS + TLS 1.3 Sauvegarde 3-2-1 air-gap	**P1-P2**
Supervision	SIEM (Wazuh/ELK) 12 règles de corrélation	**P2**
OT	Hardening PLC/SCADA ACL Modbus, firmware	**P2**

Priorisation des actions

P1 — Quick Wins 0-3 mois 15-25k EUR	MFA, Sauvegarde 3-2-1, Segmentation, EDR, WAF, Anti-phishing	60%
P2 — Consolidation 3-6 mois 30-50k EUR	SIEM, Tiering AD, MQTTS, Hardening PLC, IDS OT	80%
P3 — Maturité 6-12 mois 50-100k EUR	Audit ISO/IEC, SOC 24/7, Zero Trust, Cyber-assurance	95%

Architecture sécurisée cible



Plan de réponse à incident

Détection	Qualification	Confinement	Éradication	Restauration	Post-mortem
Alerte SIEM/EDR/IDS Signalement utilisateur	Évaluation sévérité Périmètre touché	Isolation réseau Blocage IP/compte	Suppression malware Reset credentials	Backup vérifié Validation PLC	Root cause, rapport Mise à jour SIEM
Immédiat	< 15 min	< 30 min	< 4h	< 8h	< 5 jours

Fiches réflexes disponibles

Fiche A — Ransomware	Fiche B — Compromission OT	Fiche C — Phishing + compte
Isolation IT, coupure lien OT, scanner EDR, restauration air-gap	Isolation PLC, vérification firmware SHA-256, mode manuel	Reset MDP, révoquer sessions, bloquer domaine, activer MFA

Conclusion

2 scénarios critiques
Sabotage PLC et Ransomware (criticité 12/16)

6 simulations concluantes
Segmentation insuffisante, 28% clic phishing, MQTT en clair

Plan de sécurisation actionnable
16 mesures tech + 6 orga, priorisées P1/P2/P3

Merci — Questions ?